

# RAPPORT DE SÉCURITÉ ORTHRUS

Date du Scan

2026-05-30 18:43:11

Cible

<https://petstore3.swagger.io/api/v3/openapi.json>

## Avertissement Légal & Confidentialité

Ce rapport est STRICTEMENT CONFIDENTIEL et sa distribution est soumise à restriction. Il est destiné uniquement au personnel autorisé. Il est généré par un outil automatisé de test de sécurité (Orthrus). L'outil assigne un score CVSS de Base théorique qui peut ne pas refléter le contexte environnemental ou temporel de la vulnérabilité. Les auteurs et l'outil lui-même déclinent toute responsabilité en cas de vulnérabilité non détectée, de failles critiques manquées, ou de compromissions ultérieures des systèmes testés. Cet outil est fourni exclusivement pour des tests de sécurité autorisés et encadrés.

## Méthodologie et Critères d'Évaluation

Ce rapport présente les résultats d'une analyse automatisée de sécurité dynamique (DAST). L'analyse a consisté à envoyer divers payloads malveillants et des entrées inattendues à l'API cible afin d'identifier les vulnérabilités de sécurité.

Orthrus utilise une taxonomie avancée pour catégoriser ses découvertes.

- **Score CVSS 3.1 Base** : Fournit un score numérique théorique (0.0 à 10.0) reflétant les qualités intrinsèques de la vulnérabilité.
- **CAPEC** : Common Attack Pattern Enumeration and Classification, identifiant le mécanisme exact de l'attaque.
- **OWASP** : Lie chaque vulnérabilité au classement de sécurité API Top 10 le plus récent.
- **Note de Sécurité Globale** : Une note (de A à F) évaluant la posture globale de sécurité, basée sur la vulnérabilité de plus haute criticité trouvée.

# Résumé Global

Note de Sécurité

F

| Total des Vulnérabilités | CRITIQUE | ÉLEVÉ | MOYEN | FAIBLE | INFO |
|--------------------------|----------|-------|-------|--------|------|
| 99                       | 3        | 6     | 13    | 77     | 0    |

# Résultats Détaillés

**Catégorie OWASP:** Injection | **Confiance:** HIGH

Score CVSS de Base: 9.8

78

CAPEC-88

**CWE**

CWE-78: Neutralisation incorrecte des éléments spéciaux utilisés dans une commande système ('OS Command Injection')

**Point de  
Terminaison**

GET <https://petstore3.swagger.io/api/v3/pet/findByStatus>

**Description**

Le point de terminaison exécute des commandes fournies par l'utilisateur sur le système d'exploitation sous-jacent.

**Remédiation**

Évitez d'exécuter des commandes système directement. Si nécessaire, utilisez des API de bas niveau sûres et validez rigoureusement les entrées (allowlist).

**Preuve**

```
Response contains the injected marker string  
'VULNAPI_CMD_INJECT_SUCCESS', indicating the OS command  
was executed and its output was returned.
```

**Catégorie OWASP:** Injection | **Confiance:** HIGH

Score CVSS de Base: 9.8

1336

CAPEC-137

### CWE

CWE-1336: Neutralisation incorrecte des éléments spéciaux utilisés dans un moteur de template

### Point de Terminaison

GET <https://petstore3.swagger.io/api/v3/user/login>

### Description

Le point de terminaison évalue l'entrée utilisateur comme du code de template, permettant l'exécution de code arbitraire sur le serveur.

### Remédiation

N'utilisez jamais d'entrées utilisateur directement dans l'évaluation d'un template. Utilisez des moteurs de template sans logique ou exécutez-les dans un environnement bac à sable sécurisé.

### Preuve

Response contains the evaluated result ('49') of the injected template expression '{{7\*7}}'.

### 3. Server-Side Template Injection (SSTI)

[CRITIQUE]

Catégorie OWASP: Injection | Confiance: HIGH

Score CVSS de Base: 9.8

1336

CAPEC-137

#### CWE

CWE-1336: Neutralisation incorrecte des éléments spéciaux utilisés dans un moteur de template

#### Point de Terminaison

GET <https://petstore3.swagger.io/api/v3/user/login>

#### Description

Le point de terminaison évalue l'entrée utilisateur comme du code de template, permettant l'exécution de code arbitraire sur le serveur.

#### Remédiation

N'utilisez jamais d'entrées utilisateur directement dans l'évaluation d'un template. Utilisez des moteurs de template sans logique ou exécutez-les dans un environnement bac à sable sécurisé.

#### Preuve

Response contains the evaluated result ('49') of the injected template expression '\${7\*7}'.

Catégorie OWASP: Injection | Confiance: MEDIUM

Score CVSS de Base: 9.8

943

CAPEC-66

### CWE

CWE-943: Neutralisation incorrecte des éléments spéciaux dans la logique de requête de données

### Point de Terminaison

GET <https://petstore3.swagger.io/api/v3/pet/findByTags>

### Description

Le point de terminaison pourrait être vulnérable à une injection NoSQL (ex: MongoDB).

### Remédiation

N'insérez pas directement les données utilisateur dans les requêtes de base de données. Utilisez les fonctionnalités de requêtage sécurisées fournies par votre client NoSQL.

### Preuve

```
Response indicates a NoSQL database error when payload  
'{"$ne": null}' was injected.
```

Catégorie OWASP: Injection | Confiance: MEDIUM

Score CVSS de Base: 9.8

89

CAPEC-66

### CWE

CWE-89: Neutralisation incorrecte des éléments spéciaux dans une commande SQL ('Injection SQL')

### Point de Terminaison

GET <https://petstore3.swagger.io/api/v3/pet/findByTags>

### Description

Le point de terminaison pourrait être vulnérable à une injection SQL.

### Remédiation

Utilisez des requêtes paramétrées (Prepared Statements) ou des ORM. N'interpolez jamais directement les entrées utilisateur dans les requêtes SQL.

### Preuve

Response indicates a database error when payload '' OR '1'='1' was injected.

**Catégorie OWASP:** Injection | **Confiance:** MEDIUM

Score CVSS de Base: 9.8

943

CAPEC-66

**CWE**

CWE-943: Neutralisation incorrecte des éléments spéciaux dans la logique de requête de données

**Point de  
Terminaison**

POST <https://petstore3.swagger.io/api/v3/pet/10>

**Description**

Le point de terminaison pourrait être vulnérable à une injection NoSQL (ex: MongoDB).

**Remédiation**

N'insérez pas directement les données utilisateur dans les requêtes de base de données. Utilisez les fonctionnalités de requêtage sécurisées fournies par votre client NoSQL.

**Preuve**

Response indicates a NoSQL database error when payload `'{"$ne": null}'` was injected.



**Catégorie OWASP:** Injection | **Confiance:** MEDIUM**Score CVSS de Base:** 9.8

943

**CAPEC-66****CWE**

CWE-943: Neutralisation incorrecte des éléments spéciaux dans la logique de requête de données

**Point de  
Terminaison**

POST <https://petstore3.swagger.io/api/v3/pet/10>

**Description**

Le point de terminaison pourrait être vulnérable à une injection NoSQL (ex: MongoDB).

**Remédiation**

N'insérez pas directement les données utilisateur dans les requêtes de base de données. Utilisez les fonctionnalités de requêtage sécurisées fournies par votre client NoSQL.

**Preuve**

```
Response indicates a NoSQL database error when payload  
'{"$ne": null}' was injected.
```

Catégorie OWASP: Injection | Confiance: MEDIUM

Score CVSS de Base: 9.8

89

CAPEC-66

### CWE

CWE-89: Neutralisation incorrecte des éléments spéciaux dans une commande SQL ('Injection SQL')

### Point de Terminaison

POST <https://petstore3.swagger.io/api/v3/pet/10>

### Description

Le point de terminaison pourrait être vulnérable à une injection SQL.

### Remédiation

Utilisez des requêtes paramétrées (Prepared Statements) ou des ORM. N'interpolez jamais directement les entrées utilisateur dans les requêtes SQL.

### Preuve

Response indicates a database error when payload '' OR '1'='1' was injected.

**Catégorie OWASP:** Injection | **Confiance:** MEDIUM

Score CVSS de Base: 9.8

89

CAPEC-66

**CWE**

CWE-89: Neutralisation incorrecte des éléments spéciaux dans une commande SQL ('Injection SQL')

**Point de  
Terminaison**

POST <https://petstore3.swagger.io/api/v3/pet/10>

**Description**

Le point de terminaison pourrait être vulnérable à une injection SQL.

**Remédiation**

Utilisez des requêtes paramétrées (Prepared Statements) ou des ORM. N'interpolez jamais directement les entrées utilisateur dans les requêtes SQL.

**Preuve**

Response indicates a database error when payload '' OR '1'='1' was injected.

**Catégorie OWASP:** Injection | **Confiance:** HIGH

Score CVSS de Base: 6.1

79

CAPEC-63

**CWE**

CWE-79: Neutralisation incorrecte des entrées lors de la génération d'une page Web ('Cross-site Scripting')

**Point de  
Terminaison**

GET https://petstore3.swagger.io/api/v3/pet/findByStatus

**Description**

Le point de terminaison reflète l'entrée utilisateur non encodée dans la réponse.

**Remédiation**

Encodez systématiquement les données fournies par l'utilisateur avant de les afficher. Utilisez les mécanismes d'échappement natifs de votre framework.

**Preuve**

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

## 11. Missing Rate Limiting

[MOYEN]

**Catégorie OWASP:** Lack of Resources & Rate Limiting | **Confiance:** LOW

Score CVSS de Base: 5.3

799

CAPEC-115

### CWE

CWE-799: Contrôle incorrect de la fréquence d'interaction

### Point de

POST <https://petstore3.swagger.io/api/v3/pet>

### Terminaison

### Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

### Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

### Preuve

After 30 requests, the server returned status 500 instead of 429.

## 12. Missing Rate Limiting

[MOYEN]

**Catégorie OWASP:** Lack of Resources & Rate Limiting | **Confiance:** LOW

Score CVSS de Base: 5.3

799

CAPEC-115

### CWE

CWE-799: Contrôle incorrect de la fréquence d'interaction

### Point de

PUT <https://petstore3.swagger.io/api/v3/pet>

### Terminaison

### Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

### Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

### Preuve

After 30 requests, the server returned status 500 instead of 429.

## 13. Missing Rate Limiting

[MOYEN]

**Catégorie OWASP:** Lack of Resources & Rate Limiting | **Confiance:** LOW

Score CVSS de Base: 5.3

799

CAPEC-115

### CWE

CWE-799: Contrôle incorrect de la fréquence d'interaction

### Point de

POST <https://petstore3.swagger.io/api/v3/pet/10>

### Terminaison

### Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

### Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

### Preuve

After 30 requests, the server returned status 500 instead of 429.

## 14. Missing Rate Limiting

[MOYEN]

**Catégorie OWASP:** Lack of Resources & Rate Limiting | **Confiance:** LOW

Score CVSS de Base: 5.3

799

CAPEC-115

### CWE

CWE-799: Contrôle incorrect de la fréquence d'interaction

### Point de

DELETE <https://petstore3.swagger.io/api/v3/pet/1>

### Terminaison

### Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

### Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

### Preuve

After 30 requests, the server returned status 500 instead of 429.

## 15. Missing Rate Limiting

[MOYEN]

**Catégorie OWASP:** Lack of Resources & Rate Limiting | **Confiance:** LOW

Score CVSS de Base: 5.3

799

CAPEC-115

### CWE

CWE-799: Contrôle incorrect de la fréquence d'interaction

### Point de

### Terminaison

POST <https://petstore3.swagger.io/api/v3/pet/66/uploadImage>

### Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

### Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

### Preuve

After 30 requests, the server returned status 400 instead of 429.

## 16. Missing Rate Limiting

[MOYEN]

**Catégorie OWASP:** Lack of Resources & Rate Limiting | **Confiance:** LOW

Score CVSS de Base: 5.3

799

CAPEC-115

### CWE

CWE-799: Contrôle incorrect de la fréquence d'interaction

### Point de

### Terminaison

POST <https://petstore3.swagger.io/api/v3/store/order>

### Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

### Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

### Preuve

After 30 requests, the server returned status 500 instead of 429.

## 17. Missing Rate Limiting

[MOYEN]

**Catégorie OWASP:** Lack of Resources & Rate Limiting | **Confiance:** LOW

Score CVSS de Base: 5.3

799

CAPEC-115

### CWE

CWE-799: Contrôle incorrect de la fréquence d'interaction

### Point de

### Terminaison

DELETE <https://petstore3.swagger.io/api/v3/store/order/96>

### Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

### Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

### Preuve

After 30 requests, the server returned status 500 instead of 429.

## 18. Missing Rate Limiting

[MOYEN]

**Catégorie OWASP:** Lack of Resources & Rate Limiting | **Confiance:** LOW

Score CVSS de Base: 5.3

799

CAPEC-115

### CWE

CWE-799: Contrôle incorrect de la fréquence d'interaction

### Point de

### Terminaison

POST <https://petstore3.swagger.io/api/v3/user>

### Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

### Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

### Preuve

After 30 requests, the server returned status 500 instead of 429.



## 19. Missing Rate Limiting

[MOYEN]

**Catégorie OWASP:** Lack of Resources & Rate Limiting | **Confiance:** LOW

Score CVSS de Base: 5.3

799

CAPEC-115

### CWE

CWE-799: Contrôle incorrect de la fréquence d'interaction

### Point de

### Terminaison

POST <https://petstore3.swagger.io/api/v3/user/createWithList>

### Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

### Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

### Preuve

After 30 requests, the server returned status 400 instead of 429.

## 20. Missing Rate Limiting

[MOYEN]

**Catégorie OWASP:** Lack of Resources & Rate Limiting | **Confiance:** LOW

Score CVSS de Base: 5.3

799

CAPEC-115

### CWE

CWE-799: Contrôle incorrect de la fréquence d'interaction

### Point de

### Terminaison

GET <https://petstore3.swagger.io/api/v3/user/login>

### Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

### Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

### Preuve

After 30 requests, the server returned status 200 instead of 429.

## 21. Missing Rate Limiting

[MOYEN]

**Catégorie OWASP:** Lack of Resources & Rate Limiting | **Confiance:** LOW

Score CVSS de Base: 5.3

799

CAPEC-115

### CWE

CWE-799: Contrôle incorrect de la fréquence d'interaction

### Point de Terminaison

DELETE <https://petstore3.swagger.io/api/v3/user/explicabo>

### Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

### Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

### Preuve

After 30 requests, the server returned status 500 instead of 429.

## 22. Missing Rate Limiting

[MOYEN]

**Catégorie OWASP:** Lack of Resources & Rate Limiting | **Confiance:** LOW

Score CVSS de Base: 5.3

799

CAPEC-115

### CWE

CWE-799: Contrôle incorrect de la fréquence d'interaction

### Point de Terminaison

PUT <https://petstore3.swagger.io/api/v3/user/deserunt>

### Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

### Remédiation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

### Preuve

After 30 requests, the server returned status 500 instead of 429.

## 23. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

### Terminaison

GET https://petstore3.swagger.io/api/v3/pet/findByStatus

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Strict-Transport-Security' is missing from the response.

## 24. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

### Terminaison

GET https://petstore3.swagger.io/api/v3/pet/findByStatus

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'X-Content-Type-Options' is missing from the response.

## 25. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

### CWE

CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres

### Point de Terminaison

GET https://petstore3.swagger.io/api/v3/pet/findByStatus

### Description

The HTTP response does not contain the 'X-Frame-Options' security header.

### Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

### Preuve

Header 'X-Frame-Options' is missing from the response.

## 26. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de Terminaison

GET https://petstore3.swagger.io/api/v3/pet/findByStatus

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Content-Security-Policy' is missing from the response.

## 27. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

POST <https://petstore3.swagger.io/api/v3/pet>

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Strict-Transport-Security' is missing from the response.

## 28. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

POST <https://petstore3.swagger.io/api/v3/pet>

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'X-Content-Type-Options' is missing from the response.

## 29. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

### CWE

CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres

### Point de Terminaison

POST <https://petstore3.swagger.io/api/v3/pet>

### Description

The HTTP response does not contain the 'X-Frame-Options' security header.

### Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

### Preuve

Header 'X-Frame-Options' is missing from the response.

## 30. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de Terminaison

POST <https://petstore3.swagger.io/api/v3/pet>

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Content-Security-Policy' is missing from the response.

## 31. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

### Terminaison

GET https://petstore3.swagger.io/api/v3/pet/findByTags

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Strict-Transport-Security' is missing from the response.

## 32. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

### Terminaison

GET https://petstore3.swagger.io/api/v3/pet/findByTags

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'X-Content-Type-Options' is missing from the response.

### 33. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

#### CWE

CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres

#### Point de Terminaison

GET https://petstore3.swagger.io/api/v3/pet/findByTags

#### Description

The HTTP response does not contain the 'X-Frame-Options' security header.

#### Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

#### Preuve

Header 'X-Frame-Options' is missing from the response.

### 34. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

#### CWE

CWE-693: Échec du mécanisme de protection

#### Point de Terminaison

GET https://petstore3.swagger.io/api/v3/pet/findByTags

#### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

#### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

#### Preuve

Header 'Content-Security-Policy' is missing from the response.



## 35. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

GET https://petstore3.swagger.io/api/v3/pet/52

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Strict-Transport-Security' is missing from the response.

## 36. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

GET https://petstore3.swagger.io/api/v3/pet/52

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'X-Content-Type-Options' is missing from the response.

## 37. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

### CWE

CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres

### Point de Terminaison

GET https://petstore3.swagger.io/api/v3/pet/52

### Description

The HTTP response does not contain the 'X-Frame-Options' security header.

### Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

### Preuve

Header 'X-Frame-Options' is missing from the response.

## 38. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de Terminaison

GET https://petstore3.swagger.io/api/v3/pet/52

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Content-Security-Policy' is missing from the response.

### 39. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

#### CWE

CWE-693: Échec du mécanisme de protection

#### Point de

PUT <https://petstore3.swagger.io/api/v3/pet>

#### Terminaison

#### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

#### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

#### Preuve

Header 'Strict-Transport-Security' is missing from the response.

### 40. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

#### CWE

CWE-693: Échec du mécanisme de protection

#### Point de

POST <https://petstore3.swagger.io/api/v3/pet/10>

#### Terminaison

#### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

#### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

#### Preuve

Header 'Strict-Transport-Security' is missing from the response.

## 41. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

POST <https://petstore3.swagger.io/api/v3/pet/10>

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'X-Content-Type-Options' is missing from the response.

## 42. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

### CWE

CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres

### Point de

POST <https://petstore3.swagger.io/api/v3/pet/10>

### Terminaison

### Description

The HTTP response does not contain the 'X-Frame-Options' security header.

### Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

### Preuve

Header 'X-Frame-Options' is missing from the response.

### 43. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

**CWE**

CWE-693: Échec du mécanisme de protection

**Point de**

POST <https://petstore3.swagger.io/api/v3/pet/10>

**Terminaison**

**Description**

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

**Remédiation**

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

**Preuve**

Header 'Content-Security-Policy' is missing from the response.

### 44. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

**CWE**

CWE-693: Échec du mécanisme de protection

**Point de**

PUT <https://petstore3.swagger.io/api/v3/pet>

**Terminaison**

**Description**

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

**Remédiation**

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

**Preuve**

Header 'X-Content-Type-Options' is missing from the response.

## 45. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

### CWE

CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres

### Point de Terminaison

PUT <https://petstore3.swagger.io/api/v3/pet>

### Description

The HTTP response does not contain the 'X-Frame-Options' security header.

### Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

### Preuve

Header 'X-Frame-Options' is missing from the response.

## 46. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de Terminaison

PUT <https://petstore3.swagger.io/api/v3/pet>

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Content-Security-Policy' is missing from the response.

## 47. Unhandled Exception on Unexpected Content-Type

[FAIBLE]

**Catégorie OWASP:** Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 7.5

209

CAPEC-228

### CWE

CWE-209: Génération d'un message d'erreur contenant des informations sensibles

### Point de Terminaison

POST <https://petstore3.swagger.io/api/v3/pet/10>

### Description

Le point de terminaison renvoie des messages d'erreur détaillés ou des traces de pile lors du traitement d'une entrée non valide.

### Remédiation

Interceptez les exceptions côté serveur et renvoyez des messages d'erreur génériques à l'utilisateur. Ne divulguez jamais de stack traces en production.

### Preuve

```
Server returned 7.5 Internal Server Error when receiving application/xml.
```

## 48. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

### Terminaison

DELETE <https://petstore3.swagger.io/api/v3/pet/1>

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Strict-Transport-Security' is missing from the response.

## 49. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

### Terminaison

DELETE <https://petstore3.swagger.io/api/v3/pet/1>

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'X-Content-Type-Options' is missing from the response.



## 50. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

### CWE

CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres

### Point de Terminaison

DELETE <https://petstore3.swagger.io/api/v3/pet/1>

### Description

The HTTP response does not contain the 'X-Frame-Options' security header.

### Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

### Preuve

Header 'X-Frame-Options' is missing from the response.

## 51. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de Terminaison

DELETE <https://petstore3.swagger.io/api/v3/pet/1>

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Content-Security-Policy' is missing from the response.

## 52. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

GET https://petstore3.swagger.io/api/v3/store/inventory

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Strict-Transport-Security' is missing from the response.

## 53. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

GET https://petstore3.swagger.io/api/v3/store/inventory

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'X-Content-Type-Options' is missing from the response.

## 54. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

### CWE

CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres

### Point de Terminaison

GET https://petstore3.swagger.io/api/v3/store/inventory

### Description

The HTTP response does not contain the 'X-Frame-Options' security header.

### Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

### Preuve

Header 'X-Frame-Options' is missing from the response.

## 55. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de Terminaison

GET https://petstore3.swagger.io/api/v3/store/inventory

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Content-Security-Policy' is missing from the response.

## 56. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

POST <https://petstore3.swagger.io/api/v3/store/order>

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Strict-Transport-Security' is missing from the response.

## 57. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

POST <https://petstore3.swagger.io/api/v3/store/order>

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'X-Content-Type-Options' is missing from the response.

## 58. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

### CWE

CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres

### Point de Terminaison

POST <https://petstore3.swagger.io/api/v3/store/order>

### Description

The HTTP response does not contain the 'X-Frame-Options' security header.

### Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

### Preuve

Header 'X-Frame-Options' is missing from the response.

## 59. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de Terminaison

POST <https://petstore3.swagger.io/api/v3/store/order>

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Content-Security-Policy' is missing from the response.

## 60. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

|                             |                                                                                                                                                    |
|-----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>CWE</b>                  | CWE-693: Échec du mécanisme de protection                                                                                                          |
| <b>Point de Terminaison</b> | POST <a href="https://petstore3.swagger.io/api/v3/pet/66/uploadImage">https://petstore3.swagger.io/api/v3/pet/66/uploadImage</a>                   |
| <b>Description</b>          | Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.                                                                               |
| <b>Remédiation</b>          | Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy). |
| <b>Preuve</b>               | Header 'Strict-Transport-Security' is missing from the response.                                                                                   |

## 61. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

|                             |                                                                                                                                                    |
|-----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>CWE</b>                  | CWE-693: Échec du mécanisme de protection                                                                                                          |
| <b>Point de Terminaison</b> | POST <a href="https://petstore3.swagger.io/api/v3/pet/66/uploadImage">https://petstore3.swagger.io/api/v3/pet/66/uploadImage</a>                   |
| <b>Description</b>          | Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.                                                                               |
| <b>Remédiation</b>          | Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy). |
| <b>Preuve</b>               | Header 'X-Content-Type-Options' is missing from the response.                                                                                      |

## 62. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

|                             |                                                                                                                                  |
|-----------------------------|----------------------------------------------------------------------------------------------------------------------------------|
| <b>CWE</b>                  | CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres                                   |
| <b>Point de Terminaison</b> | POST <a href="https://petstore3.swagger.io/api/v3/pet/66/uploadImage">https://petstore3.swagger.io/api/v3/pet/66/uploadImage</a> |
| <b>Description</b>          | The HTTP response does not contain the 'X-Frame-Options' security header.                                                        |
| <b>Remédiation</b>          | Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.                     |
| <b>Preuve</b>               | Header 'X-Frame-Options' is missing from the response.                                                                           |

## 63. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

|                             |                                                                                                                                                    |
|-----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>CWE</b>                  | CWE-693: Échec du mécanisme de protection                                                                                                          |
| <b>Point de Terminaison</b> | POST <a href="https://petstore3.swagger.io/api/v3/pet/66/uploadImage">https://petstore3.swagger.io/api/v3/pet/66/uploadImage</a>                   |
| <b>Description</b>          | Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.                                                                               |
| <b>Remédiation</b>          | Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy). |
| <b>Preuve</b>               | Header 'Content-Security-Policy' is missing from the response.                                                                                     |

## 64. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

GET https://petstore3.swagger.io/api/v3/store/order/80

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Strict-Transport-Security' is missing from the response.

## 65. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

GET https://petstore3.swagger.io/api/v3/store/order/80

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'X-Content-Type-Options' is missing from the response.



## 66. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

### CWE

CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres

### Point de Terminaison

GET https://petstore3.swagger.io/api/v3/store/order/80

### Description

The HTTP response does not contain the 'X-Frame-Options' security header.

### Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

### Preuve

Header 'X-Frame-Options' is missing from the response.

## 67. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de Terminaison

GET https://petstore3.swagger.io/api/v3/store/order/80

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Content-Security-Policy' is missing from the response.

## 68. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

### Terminaison

DELETE <https://petstore3.swagger.io/api/v3/store/order/96>

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Strict-Transport-Security' is missing from the response.

## 69. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

### Terminaison

DELETE <https://petstore3.swagger.io/api/v3/store/order/96>

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'X-Content-Type-Options' is missing from the response.

## 70. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

### CWE

CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres

### Point de Terminaison

DELETE <https://petstore3.swagger.io/api/v3/store/order/96>

### Description

The HTTP response does not contain the 'X-Frame-Options' security header.

### Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

### Preuve

Header 'X-Frame-Options' is missing from the response.

## 71. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de Terminaison

DELETE <https://petstore3.swagger.io/api/v3/store/order/96>

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Content-Security-Policy' is missing from the response.

## 72. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

POST <https://petstore3.swagger.io/api/v3/user>

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Strict-Transport-Security' is missing from the response.

## 73. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

POST <https://petstore3.swagger.io/api/v3/user>

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'X-Content-Type-Options' is missing from the response.

## 74. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

### CWE

CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres

### Point de Terminaison

POST <https://petstore3.swagger.io/api/v3/user>

### Description

The HTTP response does not contain the 'X-Frame-Options' security header.

### Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

### Preuve

Header 'X-Frame-Options' is missing from the response.

## 75. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de Terminaison

POST <https://petstore3.swagger.io/api/v3/user>

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Content-Security-Policy' is missing from the response.

## 76. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

### Terminaison

POST <https://petstore3.swagger.io/api/v3/user/createWithList>

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Strict-Transport-Security' is missing from the response.

## 77. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

### Terminaison

POST <https://petstore3.swagger.io/api/v3/user/createWithList>

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'X-Content-Type-Options' is missing from the response.

## 78. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

### CWE

CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres

### Point de Terminaison

POST <https://petstore3.swagger.io/api/v3/user/createWithList>

### Description

The HTTP response does not contain the 'X-Frame-Options' security header.

### Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

### Preuve

Header 'X-Frame-Options' is missing from the response.

## 79. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de Terminaison

POST <https://petstore3.swagger.io/api/v3/user/createWithList>

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Content-Security-Policy' is missing from the response.

## 80. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

### Terminaison

GET https://petstore3.swagger.io/api/v3/user/login

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Strict-Transport-Security' is missing from the response.

## 81. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

### Terminaison

GET https://petstore3.swagger.io/api/v3/user/login

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'X-Content-Type-Options' is missing from the response.



## 82. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

### CWE

CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres

### Point de Terminaison

GET https://petstore3.swagger.io/api/v3/user/login

### Description

The HTTP response does not contain the 'X-Frame-Options' security header.

### Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

### Preuve

Header 'X-Frame-Options' is missing from the response.

## 83. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de Terminaison

GET https://petstore3.swagger.io/api/v3/user/login

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Content-Security-Policy' is missing from the response.

## 84. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

GET https://petstore3.swagger.io/api/v3/user/logout

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Strict-Transport-Security' is missing from the response.

## 85. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

GET https://petstore3.swagger.io/api/v3/user/logout

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'X-Content-Type-Options' is missing from the response.

## 86. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

### CWE

CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres

### Point de Terminaison

GET https://petstore3.swagger.io/api/v3/user/logout

### Description

The HTTP response does not contain the 'X-Frame-Options' security header.

### Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

### Preuve

Header 'X-Frame-Options' is missing from the response.

## 87. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de Terminaison

GET https://petstore3.swagger.io/api/v3/user/logout

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Content-Security-Policy' is missing from the response.

## 88. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

GET https://petstore3.swagger.io/api/v3/user/sit

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Strict-Transport-Security' is missing from the response.

## 89. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

GET https://petstore3.swagger.io/api/v3/user/sit

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'X-Content-Type-Options' is missing from the response.

## 90. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

### CWE

CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres

### Point de Terminaison

GET https://petstore3.swagger.io/api/v3/user/sit

### Description

The HTTP response does not contain the 'X-Frame-Options' security header.

### Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

### Preuve

Header 'X-Frame-Options' is missing from the response.

## 91. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de Terminaison

GET https://petstore3.swagger.io/api/v3/user/sit

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Content-Security-Policy' is missing from the response.

## 92. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

PUT <https://petstore3.swagger.io/api/v3/user/deserunt>

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Strict-Transport-Security' is missing from the response.

## 93. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

PUT <https://petstore3.swagger.io/api/v3/user/deserunt>

### Terminaison

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'X-Content-Type-Options' is missing from the response.

## 94. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

### CWE

CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres

### Point de Terminaison

PUT <https://petstore3.swagger.io/api/v3/user/deserunt>

### Description

The HTTP response does not contain the 'X-Frame-Options' security header.

### Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

### Preuve

Header 'X-Frame-Options' is missing from the response.

## 95. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de Terminaison

PUT <https://petstore3.swagger.io/api/v3/user/deserunt>

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Content-Security-Policy' is missing from the response.

## 96. Missing Security Header: HSTS

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

### Terminaison

DELETE <https://petstore3.swagger.io/api/v3/user/explicabo>

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Strict-Transport-Security' is missing from the response.

## 97. Missing Security Header: X-Content-Type-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de

### Terminaison

DELETE <https://petstore3.swagger.io/api/v3/user/explicabo>

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'X-Content-Type-Options' is missing from the response.



## 98. Missing Security Header: X-Frame-Options

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

1021

CAPEC-310

### CWE

CWE-1021: Restriction incorrecte des couches de rendu de l'interface utilisateur ou des cadres

### Point de Terminaison

DELETE <https://petstore3.swagger.io/api/v3/user/explicabo>

### Description

The HTTP response does not contain the 'X-Frame-Options' security header.

### Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

### Preuve

Header 'X-Frame-Options' is missing from the response.

## 99. Missing Security Header: CSP

[FAIBLE]

Catégorie OWASP: Security Misconfiguration | **Confiance:** HIGH

Score CVSS de Base: 4.3

693

CAPEC-310

### CWE

CWE-693: Échec du mécanisme de protection

### Point de Terminaison

DELETE <https://petstore3.swagger.io/api/v3/user/explicabo>

### Description

Un en-tête de sécurité HTTP recommandé est manquant dans la réponse.

### Remédiation

Configurez les en-têtes de sécurité HTTP appropriés (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy).

### Preuve

Header 'Content-Security-Policy' is missing from the response.

